セキュリティインシデント発生時の対応方針

セキュリティインシデント発生時には、以下の対応方針に則って対応を進める。

No.	対応内容（概要）	行動主体	対象環境	具体的なアクション例
①	漏洩した情報資産の内容、保管場所および使用者を特定する。	共同 (KDDI / Iret)	両方 (オンプレ / AWS)	KDDIは、漏洩した情報のビジネス上の重要性を判断。 Iretは、CloudTrailやS3のアクセスログを分析し、技術的な流出経路と影響範囲を特定。
②	必要に応じて漏洩データの防御、検出端末を隔離する。	Iret (AWS)、KDDI (オンプレ)	両方 (オンプレ / AWS)	[AWS] KDDI、Iretとの協議の上、漏洩したIAMキーを早急に無効化。疑わしい通信の送信元IPをネットワークACLでブロック。 [オンプレ] 影響を受けたZabbixサーバー等を、ネットワークから隔離。
③	アクセス権限設定の再確認を依頼し、不審点があれば究明する。	Iret (AWS)、KDDI (オンプレ)	両方 (オンプレ / AWS)	[AWS] Iretは、関連するS3バケットポリシーやIAMポリシーに、不備がないかを緊急レビュー。 [オンプレ] KDDIは、関連するサーバー等のアクセス権を再確認。
④	疑わしいハードウェア、ソフトウェアがあれば、原因を追及、除去する。	Iret (AWS)、KDDI (オンプレ)	両方 (オンプレ / AWS)	[AWS] GuardDutyの検知結果に基づき、Iretが不正なアクティビティの原因を調査。 [オンプレ] KDDIセキュリティ部門と連携し、マルウェアスキャン等を実施。
⑤	資料ファイルの紛失、盗難などにより機密漏洩が危惧される場合は、可能な限り回収に努める。	KDDI	オンプレミス	KDDIの情報セキュリティ部門と連携し、物理的なセキュリティインシデントとして対応。 Iretは、AWS上のアクセスログ等の情報提供に協力する。